Decentralized Authorization and Authentication Based on Consortium Blockchain

Ao Zhang(✉) and Xiaoying Bai(✉)

Department of Computer Science and Technology, Tsinghua university, Beijing, China
za17@mails.tsinghua.edu.cn, baixy@mail.tsinghua.edu.cn

Abstract. With the development of digital society, the number of Internet platforms increases rapidly and a huge amount of personal information is stored online. It is convenient for users to log in to all platforms with a common account. Third-party authorization protocols like OAuth 2.0 allow the delegation of access control to dedicated service providers. However, OAuth protocol follows the centralized approach to manage authorization and authentication information, which relies on a centralized party and makes it a target under attack. In practice, it is vulnerable to attacks like replay attack, cross-site request forgery (CSRF) attack, and so on. Also, the centralized party cannot provide customized access control for other platforms. To solve these problems, the paper proposes a consortium blockchain architecture and designs protocols for account management and distributed consensus. The paper discusses the potentials of the proposed approach to effectively address certain vulnerabilities in current OAuth-like authorization and authentication services with tolerable performance.

Keywords: Decentralized authorization and authentication · Consortium blockchain · Attribute-based access control model · Adapted PBFT protocol · OAuth-like protocol

1 Introduction

As technologies reshaping our life, more and more social activities are moving into the Internet. The number of Internet platforms increases rapidly and a large amount of personal data are collected and managed by large platforms, thus the access control system is extremely important to protect the security and privacy of user data. Traditional access control models can manage authorization and authentication in a standalone system. However, for the platforms, cross-platform data interaction becomes more frequent. For the users, a single account to manage data across all platforms is needed. OAuth protocol [4] was proposed to allow the delegation of access control to third-party platforms, which has been widely used in many platforms such as Google and Facebook. For example, we

© Springer Nature Singapore Pte Ltd. 2020
Z. Zheng et al. (Eds.): BlockSys 2019, CCIS 1156, pp. 267–272, 2020.
https://doi.org/10.1007/978-981-15-2777-7_22

can log in to other platforms using Google account and provide our avatar and nickname stored in Google. However, the third-party services are usually built on centralized authorization and authentication systems that are vulnerable to security risks from both internal and external attacks. First, the access control of a third-party platform depends on the large platform like Google, which means Google can pretend to be user and access data stored in the third-party platform. Second, insecure implementations of OAuth 2.0 may lead to replay attacks, impersonation attacks, CSRF attacks, and so on.

As the underlying technology of Bitcoin [6], Blockchain introduced a decentralized architecture so that every node in the network participates in the maintenance of a consensus ledger. Transactions recorded on the shared ledger are transparent to and validated by, every participant. In recent years, there are some attempts to build access control systems based on blockchain technology in various fields such as mobile phone [7], medical data protection [1], and IoT [3].

In counter to the vulnerabilities of a centralized authorization protocol, this paper proposes a blockchain-based authorization and authentication framework, using a consortium blockchain to replace the centralized database and to enhance system defensive capabilities with a consensus protocol for identity and authentication validation. The system follows the attribute-based access control (ABAC) model [5] and bases on the consortium blockchain architecture. The permitted nodes participating in the federation can: (1) share a ledger of user identities and privileges; (2) share the ledger for tracing authorization transactions; and (3) vote for the validation of users' identities and operation privileges. Compared with a traditional database, it strengthens data security with asymmetric cryptography and provides trust among different platforms. A consortium blockchain allows only licensed alliance members to participate in the network and consensus process. Because of the enhanced credibility of the participating nodes, it can take advantage of more efficient consensus algorithms and peer-to-peer data sharing mechanisms.

The main contributions of this paper are as follows: First, a consortium blockchain architecture designed for access control is proposed, which can provide security and trust between different platforms. Second, an adapted implementation for the attribute-based access control model is designed to be used in blockchain. Third, a prototype system is implemented and the preliminary experiment for performance and latency is evaluated.

2 Architecture Overview

Based on blockchain technology and the ABAC model, we propose a consortium blockchain architecture among federated nodes for third-party authorization and authentication. Figure 1 gives an overview of architecture design and workflow. Three roles are involved in the system. The client is the resource requester. It asks the resource owner for authorization and eventually requests the blockchain node to access the resource. The resource owner grants permission to access protected resources stored on the blockchain node. The proposed approach replaces

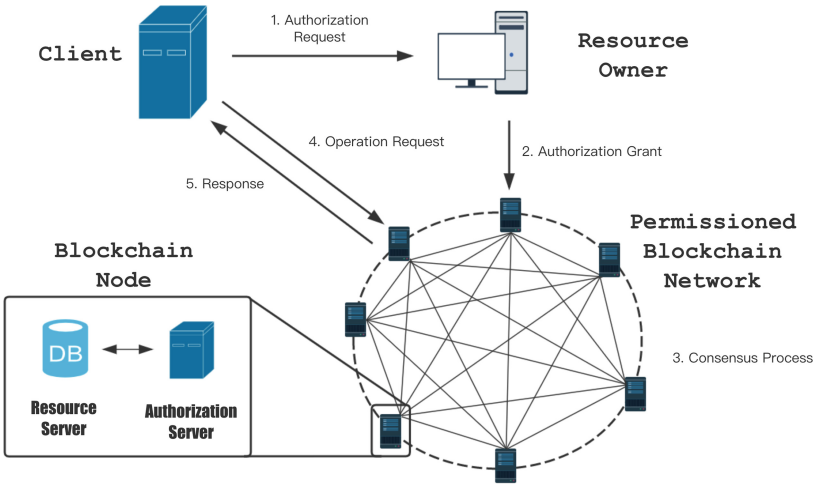

Fig. 1. The architecture of decentralized authorization and authentication

the centralized authentication server and resource server in the OAuth protocol with a consortium network. Each node in the network has equal status and participates in the storage of user authorization and authentication. The node is composed of a resource server and an authorization server. The resource server stores user resource with attributes and access control policy list, when the operation request received, the server can authenticate the attributes in the request using the access control policy list. The authorization servers manage the blockchain which stores the authorizations between users rather than transactions in cryptocurrency blockchain, and it can provide the attributes of each account for authentication in the resource server according to the blockchain. The whole process is mainly divided into five steps corresponding to the workflow in Fig. 1 and more details of each step are described in Sect. 3. The steps are as follows:

1. The client sends the *AuthorizationRequest* to the resource owner, which mainly contains the address of the client and the attributes to be authorized.
2. The resource owner verifies the *AuthorizationRequest* and sends the corresponding *AuthorizationGrant* to any blockchain node if it agrees.
3. If the received *AuthorizationGrant* is valid, the blockchain node will accept it and broadcast it in the network. After the consensus process, the authorization will be packaged into a new block and logged on the blockchain.
4. The client sends the *OperationRequest* with signature to the blockchain node which stores the resource it needs.
5. The resource server verifies the *OperationRequest* according to the attribute-based access control policy and replies to the client.

The system improves the security in centralized protocols like OAuth in several aspects. First, decentralized architecture can effectively reduce the severity

of the attack. In a centralized protocol, once the attacker breaks into the centralized authorization server, he can pretend to be any user by issuing a forged token to access the protected resource in the third-party platform. However, in the decentralized system with consensus protocols, the attacker can only access the resource stored in the server which is broken. Because the secret key is kept locally by the user, the operation and authorization from the user cannot be forged, which protects the resource stored in other platforms. Second, the digital signature used in the system can prevent the CSRF attack. The OAuth-like protocol is widely implemented behind the website and connects different platforms using a redirected URL, which may bring the CSRF attack. For example, it is often used for account binding between the centralized platform and the third-party platform. The attacker can first access the authorized server to obtain an access token for binding accounts in the third-party platform and the centralized platform, and then induce the user to send the binding request to the client and provide the token obtained by the attacker in advance. As a result, the attacker can access the user's resources in the third-party platform through the account of the centralized platform. In our system, all authorizations and operations sent from the user need to be digitally signed, which can guarantee the source of the authorization. Third, the third-party platform sends the client secret to the centralized platform and retrieves the access token which makes it possible for the attacker to listen and replay the request to get the access token. In our system, there is no centralized platform to manage secret values for other platforms and every platform can get authorization directly from the user.

3 Protocol Design

This part describes the details in the system including the data structures in the blockchain, the attribute-based access control policy and the adapted PBFT protocol in the consensus process.

3.1 Blockchain Related Data Structure

In this system, we adopt the account state model from Ethereum rather than the UTXO model in Bitcoin, because the account state model is more suitable for the ABAC model. An account owns an address, a nonce value and several attributes. Each attribute has a name and a validity period. Once necessary, an account can authorize any of the attributes to another account, while the validity period of attributes authorized cannot exceed the original one. The authorization from an account to another contains the addresses of two accounts and the attributes authorized. Blockchain is the fundamental data structure used in our system to store authorizations. According to the authorizations stored in the blockchain, we can calculate the state of each account containing the address, the nonce, and the attributes under the account. The state is saved in memory and can be used to validate authorizations or operations from this account. As for the nonce value in the account state, it inits as 0 and increases by one when one

authorization from the account is recorded on the blockchain. Any authorization with mismatched nonce value will be rejected. This can prevent the replay attack because once the authorization recorded on the blockchain, it cannot be accepted again due to the increased nonce value.

3.2 Attribute-Based Access Control Policy

This system is based on the Attribute-Based Access Control (ABAC) model, which defines four kinds of attributes: object attributes, subject attributes, operation attributes, and environment attributes. The resource server authenticates operation with these attributes according to the ABAC policy list. Each policy in the list contains four kinds of attributes and if the operation matches any one of them, it can pass the authentication. The object attributes are the attributes of the resource stored in the resource server. The subject attributes are attributes of account derived from the blockchain among authorization servers. The operation attributes are the operation type defined by the node. The environment attribute is the timestamp in the operation.

3.3 Adapted PBFT Algorithm

In the traditional distributed consensus domain such as database, researchers have proposed various consensus algorithms to ensure the consistency of data among distributed nodes and provide Byzantine Fault Tolerance (BFT) feature. The widely used BFT protocol is Practical Byzantine Fault Tolerance (PBFT) [2] proposed in 1999. We use an adapted PBFT algorithm in the access control system to help nodes maintain the same authorization ledger. The differences are as follows. The primary node in the PBFT protocol starts a new consensus process when it receives a request from the client. In our system, it starts a new consensus process in a solid interval and packages authorizations into a new block. In PBFT, view change happens when backup nodes find that the primary node seems to break down or be hacked. Beyond that, when it is long enough, nodes in our system also carry out a view change. This can prevent the malicious primary node to exclude some valid authorizations.

4 Prototype Implementation and Preliminary Experiment

We implement a prototype system to verify the feasibility of the designed framework and protocol and evaluate its performance and latency. The system is coded in the Go programming language. The resource server stores protected resources in MongoDB. In the blockchain network, communication among nodes is implemented using HTTP. The system mainly contains the client and the blockchain node. The client is used for users to manage their accounts, authorizations, and operations. The client interacts with the blockchain node after generating the operations and authorizations. The blockchain node contains an authorization

server and a resource server: The authorization servers among nodes in the network maintain the same blockchain storing authorizations between clients with PBFT protocol. The resource manages the database according to the local ABAC policy list and consensus result from the authorization server. The authorization state of accounts among all nodes are the same while the databases are different.

To evaluate the performance of this system, we implement the prototype system and deploy 4 blockchain nodes on the Microsoft Azure cloud platform. Each server is a standard D2s v3 machine, with 2 vCPU, 2G memory, and 1,000 MBps bandwidth. A new block is generated every 2 s, and each block contains at most 1000 authorizations. In the test cases, 1000 pairs of keys are generated to simulate 1000 users with different attributes, then 10000 random authorizations are generated and sent to the four blockchain nodes at the speed of 500 authorizations per second, and the servers successfully process these requests in about 21 s. The result shows that the system reached the performance of about 500 TPS (transactions per second) and the latency is 1.2 s on average.

5 Summary and Conclusion

The paper proposes a decentralized access control framework based on a consortium blockchain, following the attribute-based access control model. The framework uses the asymmetric cryptosystem, which aims to enhance the security of OAuth-like protocols in many aspects, such as data transmission and storage. The authorization server in OAuth protocol is replaced by the decentralized consortium blockchain system, where authorizations are maintained by multiple nodes using PBFT consensus protocol. A preliminary experiment on the prototype system shows that it provides a promising solution with acceptable performance for access control.

References

1. Azaria, A., Ekblaw, A., Vieira, T., Lippman, A.: Medrec: using blockchain for medical data access and permission management. In: 2016 2nd International Conference on Open and Big Data (OBD), pp. 25–30. IEEE (2016)
2. Castro, M., Liskov, B., et al.: Practical byzantine fault tolerance. In: OSDI, vol. 99, pp. 173–186 (1999)
3. Ding, S., Cao, J., Li, C., Fan, K., Li, H.: A novel attribute-based access control scheme using blockchain for IoT. IEEE Access **7**, 38431–38441 (2019)
4. Hardt, D.: The OAuth 2.0 Authorization Framework. RFC 6749, October 2012. https://doi.org/10.17487/RFC6749. https://rfc-editor.org/rfc/rfc6749.txt
5. Hu, V.C., et al.: Guide to attribute based access control (ABAC) definition and considerations (Draft). NIST Special Publication 800–162 (2013)
6. Nakamoto, S., et al.: Bitcoin: a peer-to-peer electronic cash system (2008). https://bitcoin.org/bitcoin.pdf
7. Zyskind, G., Nathan, O., et al.: Decentralizing privacy: using blockchain to protect personal data. In: 2015 IEEE Security and Privacy Workshops, pp. 180–184. IEEE (2015)